

SaveHatke — Security Audit & Hardening

Summary report · Google-only authentication · two-admin model · payment & coupon integrity · abuse protection

Headline

Verification	Result
Automated security regression suite (npm run verify:security)	120 checks — 0 failures
Fail-closed financial-write verifier (npm run verify:fail-closed)	8 checks — 0 failures
Production dependency audit (npm audit --omit=dev)	0 vulnerabilities
Authentication	Google Login enabled · Email-only login disabled · OTP not used
Administrators	Exactly 2 · both full access · third-admin creation blocked
Coupons	Payment verified → code revealed · not verified → code stays protected
UI	Login page visually unchanged (email input and Google button intact)

Scope: 22 confirmed vulnerabilities fixed in code; 18 items remain that need deployment configuration, manual testing, or a payment-flow redesign decision. Nothing in this report claims a control is secure unless it was verified in code or by an executable test.

1. Fixed — confirmed vulnerabilities

Authentication and session

Vulnerability	Fix
Email-only session creation (POST /login, /register, /auth/google)	Disabled — 410/401. No code path anywhere turns an email address into a session.
Unverified Google identity claims trusted	Server-side verification of signature, issuer, audience, expiry, issued-at, nonce, email_verified and subject. Any failure refuses with no session.
Unauthenticated logout (could revoke another user's session)	Logout requires a valid session; revocation is scoped to the caller's own session token hash.
Fail-open session validation	Requires a live database row, Active status, unexpired expiry, and a non-empty verified Google subject. Missing schema refuses rather than passes.
Hard-coded JWT fallback secret	Startup fails unless JWT_SECRET is supplied and at least 32 bytes. Secret never reaches frontend code, responses, logs or Git.
Bearer tokens bypassing revocation	Cookie-only authentication; Authorization headers are ignored everywhere.

Coupons and payments

Vulnerability	Fix
Chatbot revealed coupon codes on an email match alone (newly found in this audit)	Codes now require a PAID order plus its linked PAID payment for the same coupon at the same amount, matching the REST gate.
Payment-email spoofing via a duplicated Authentication-Results header	The first header now wins and duplicates are refused, closing the DMARC-spoof path.
Financial writes silently 'succeeded' into process memory during a Sheets outage	Strict writes must be acknowledged by Google Sheets; strict reads refuse the in-memory mirror; settlement refuses before the irreversible coupon flip.
Availability probe could never fail	Now uses a strict read, so an outage is reported instead of assumed healthy.
Admin payout approve/reject reported success on a failed write	Strict write followed by a compare-and-set re-read; a lost race returns 409, a failed write returns 503.
Refund writes discarded their own unique-constraint errors	Constraint violations are inspected and surfaced; a non-terminal transition can no longer overwrite a finalized refund.
Webhook signature covered a re-serialised body on URL variants	Raw-body capture is path-normalised, so the HMAC always covers the

	exact signed bytes.
--	---------------------

Admin, authorization and operations

Vulnerability	Fix
Admin mutation audit log recorded nothing but 404s (newly found in this audit)	The path is captured at middleware entry instead of at response time, so real admin mutations are now logged with identity, action, target and request id.
Admin Gmail push endpoint had no admin auth and compared its token with !=	Constant-time comparison, case-insensitive account match, validated history id, and non-revealing rejections.
Spoofable client IP defeated rate limiting and forged audit IPs	Only Vercel's forwarded header and the trusted-hop request IP are consulted; caller-supplied CDN headers are ignored.
Role escalation and third-admin creation	Admin status is derived server-side from the frozen two-account allowlist plus a live session; create/update/delete-admin are unconditional 403s.
Unauthenticated /api/admin/* surface	Every admin route carries authentication plus the server-side admin check; 28 admin routes probed unauthenticated returned no 2xx.

Infrastructure

Vulnerability	Fix
No Content-Security-Policy; missing Permissions-Policy; inconsistent 429 responses	Enforced frame-ancestors plus a report-only CSP that cannot break the UI; a denying Permissions-Policy; every limiter now emits the same safe 429 shape and serves the existing branded 429 page to browser navigations.
Unlocked Supabase table and open default privileges	A new migration locks every table in the public schema, not a hand-maintained list, and revokes default privileges so future tables are created closed.
Leftover debug beacon inside the module holding the Sheets private key	Removed. Diagnostics go to the protected server log instead.

Verified as already safe (no change needed): Google Sheets writes use RAW input, so formula injection is not possible; the REST coupon-reveal path is correctly payment-gated and owner-scoped; site_settings RLS is locked; the Turnstile verifier fails closed; the price tracker escapes all user input; no OTP/TOTP/password or magic-link route is mounted; and the Supabase service-role key never reaches frontend code.

2. Remaining — not fixable in code alone

Requires deployment configuration

- **Distributed rate limiting.** All limiters are in-process, so limits are per-instance and reset on cold start. Point the limiter store at Redis/Upstash or Vercel KV, and put edge/WAF rate-limit rules in front of the authentication, coupon, payment and AI endpoints.
- **Apply the new migration.** Run 20261003_lock_remaining_public_tables.sql, then confirm both verification queries in its footer return zero rows.
- **CRON_SECRET must be set.** Without it the scheduled report and Drive keepalive cannot run unattended.
- **WAF / edge protection.** The layer that must absorb volumetric attacks does not exist yet; this is a dashboard task, not a code change.

Requires manual testing

- **Real end-to-end Google login.** Every failure path is verified and forged or expired tokens are refused; a genuine successful login needs a live browser consent in staging.
- **Spoofed payment email.** Confirm the first-header fix against an actual forged message.
- **Chatbot abuse limits.** The chatbot's throttle is in-process and the AI provider is paid.

- **Live header and IP check.** Confirm the new headers are served and that a spoofed CDN header is no longer honoured in production.

Payment-flow design decisions (deliberately not rewritten)

All of these now fail closed — no coupon can be revealed and no payment is marked paid without server verification — but they are architecture decisions that need an owner's call, and changing them risks the existing user experience the brief protects.

- **Six-hour checking window versus a thirty-minute settlement cutoff.** A credit arriving in that gap is parked for review with no automatic refund record.
- **Same-amount ambiguity is exploitable as grieving.** A held payment at a deterministic price can strand a genuine credit that can never be re-matched.
- **No unique correlator binds a credit to an order.** Amount plus arrival window is the whole policy, so a payment for one order can settle another at the same price.
- **No database constraints for payments or orders.** Cross-instance duplicate live windows remain possible; the atomic coupon flip still prevents double assignment.
- **Admin payouts bypass the reservation mechanism** that the seller-payout path uses.
- **The webhook has no signed timestamp or event-id store** and the payment email's amount is parsed from free text with the payer left unverified.

3. Requirement confirmations

Requirement	Status	Evidence
Google Login enabled	Confirmed	Full authorization-code flow with PKCE, signed state cookie and server-side ID-token verification.
Email-only login disabled	Confirmed	Login and register endpoints return 410. An email address alone can never create, authenticate or restore a session.
OTP not used	Confirmed	No OTP, SMS, email-code, password or magic-link route is mounted. The legacy routers are unreachable dead code.
Authorized admins = 2	Confirmed	Startup throws unless exactly two unique active accounts are configured in server-owned config.
Both admins full access	Confirmed	Identical role, no hierarchy, no scopes, no read-only variant.
Third-admin creation blocked	Confirmed	Create, update and delete-admin are unconditional 403s; no route writes admin records.
Role escalation blocked	Confirmed	Forged role, isAdmin, email and user_id fields have zero influence across 38 probed routes.
Payment verified → coupon revealed	Confirmed	Atomic conditional coupon flip gated on a server-verified paid payment and its paid order.
Payment not verified → coupon protected	Confirmed	No endpoint accepts paid, payment_status, order_status, amount or UTR as authority.
429 with Retry-After, no leakage	Confirmed	Retry-After, no-store, safe JSON body, branded page for browser navigations, no auto-retry.
Existing UI preserved	Confirmed	Login page markup unchanged; email input and Google button present; no layout, styling or animation changed.

4. Risk position

Severity	Open items
Critical	None outstanding
High	Distributed rate limiting absent (per-instance limits); payment-flow windows and same-amount ambiguity
Medium	No unique correlator between credit and order; no payments/orders database constraints; refund sequence not transactional; admin payout surface lacks reservations; sign-in CAPTCHA not verified server-side
Low	Webhook replay lacks a signed timestamp; email amount parsed from free text; report-only CSP awaiting enforcement; documentation drift

Deliverables: verify-security.cjs (120 checks), verify-fail-closed.cjs (8 checks) and the new Supabase lockdown migration. Run everything with `npm run verify:all`. Neither verifier performs destructive or load testing and neither should be pointed at production.